

CLOUD SECURITY · AWS IAM

Assignment 17

Identity and Access Management (IAM)

A Clean, Structured Study Guide

Prepared by: Shreya Panchal

Topic: IAM Policies, Least Privilege & Access Review

Platform: Amazon Web Services (AWS)

Table of Contents

1	Task 1: Analyze Existing IAM Configuration	03
2	Task 2: Edit IAM Policy (Food Delivery App)	04
3	Task 3: Restrict S3 Read Only	05
4	Task 4: IAM Review Checklist (5 Steps)	06
5	Task 5: AI Analysis & Improvements	07

Task 1 · Analyze Existing IAM Configuration

QUESTION

Download a sample IAM policy JSON, identify users and permissions.

AWS Practical

1. AWS Console → **IAM** → Users
2. Open **foodieAppTester**
3. Go to Permissions

Tumhare user ke paas ye permissions hain:

User	Policy	Permission
foodieAppTester	FoodieAppBucketListOnly	List S3 Buckets
foodieAppTester	IAMUserChangePassword	Change Own Password

Broad Permissions (Answer)

Permission	Status	Reason
AmazonS3FullAccess	Too Broad	Full S3 access (s3:*)
AdministratorAccess	Too Broad	Access to all AWS services

Screenshot: IAM → Users → foodieAppTester → Permissions

Task 2 • Edit IAM Policy (Food Delivery App)

SCENARIO

Delivery agent order status update kar sakta hai, delete nahi.

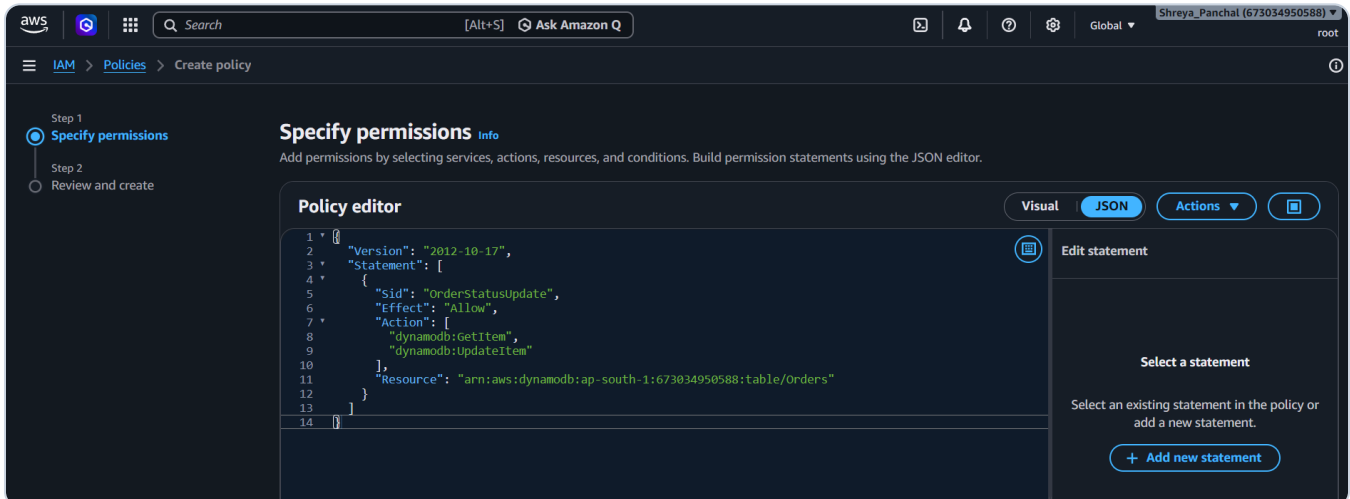
Create Policy

IAM → Policies → Create Policy → JSON – Paste Code.

Policy Name: **optimized_policy**

Explanation

Action	Allowed
GetItem	Read Order
UpdateItem	Update Status
DeleteItem	Not Allowed



Screenshot: IAM → Policies → Create Policy → JSON editor

Task 3 • Restrict S3 Read Only

SCENARIO

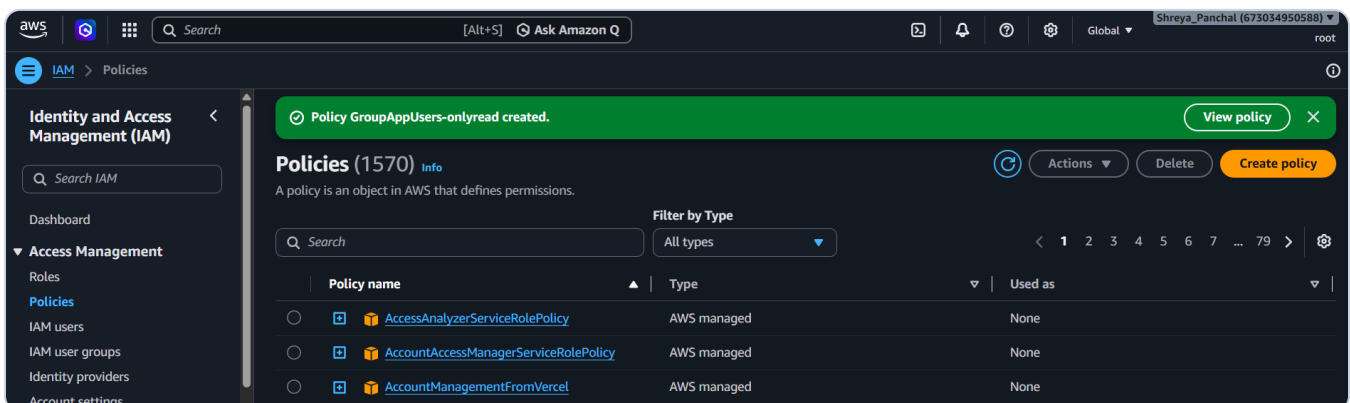
Group AppUsers can only read bucket `user-uploads` .

JSON Policy

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "ReadOnlyBucket",
      "Effect": "Allow",
      "Action": [
        "s3:GetObject",
        "s3:ListBucket"
      ],
      "Resource": [
        "arn:aws:s3:::user-uploads",
        "arn:aws:s3:::user-uploads/*"
      ]
    }
  ]
}
```

Before vs After

Before	After
s3:*	s3:GetObject
Create/Delete	Read Only



Task 4 • IAM Review Checklist (5 Steps)

INSTRUCTION

Write this in your document.

Step	Action
1	Review all IAM Users & Roles
2	Identify unused permissions
3	Remove Full Access policies
4	Enable MFA for users
5	Review policies every month

Explanation (1 line each)

- Review IAM users regularly.
- Check CloudTrail for unused permissions.
- Replace full access with custom policies.
- Enable MFA for better security.
- Perform monthly IAM audit.

TIP

A monthly IAM audit combined with CloudTrail review is the fastest way to catch unused, over-broad permissions before they become a security risk.

Task 5 • AI Analysis & Improvements

Sample Policy (Broad)

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": "s3:*",
      "Resource": "*"
    }
  ]
}
```

AI Recommendations

Improvement	Benefit
Replace s3:* with GetObject & ListBucket	Least Privilege
Limit Resource to one bucket	Better Security
Enable MFA	Stronger authentication
Review monthly	Remove unused access

DEFINITION • LEAST PRIVILEGE

Granting only the exact permissions (actions + resources) a user or role needs to do its job — nothing broader, like `s3:*` on `Resource: *`.